

Sentinel

Compliance-as-CI for healthcare and fintech

The **Bob-powered agent** that scans every pull request and **blocks merges** that ship a HIPAA / SOC 2 / PCI violation.

\$50K external audit + 6 months → \$0 + 4 minutes per PR.

The problem

Fortune 500 healthcare and fintech spend **\$5M–\$50M per company per year** on compliance audits.

Engineers chase PHI through codebases by hand for **6 months at a time** — and the violation gets shipped anyway.

Compliance is *periodic*. A quarterly audit. A release-gate scan. By the time a finding hits a Jira ticket, the engineer who wrote the violating line has moved on three sprints. The feedback loop is broken.

The insight

Compliance is a **whole-repo reasoning** problem.

A `logger.info(patient)` is only a HIPAA violation when seen through the route handler three files upstream that loaded the PHI.

- A regex sees the log line.
- A file-by-file AI sees the log line.
- An auditor's mental model sees the **flow** — and that's what `phi-tracer` mode does.

Three agentic surfaces, one Bob brain

Surface	Lives at	Closes the loop by
 Bob IDE skill pack	Every developer's editor	<code>/audit-hipaa</code> , <code>/trace-phi</code> , <code>/remediate</code> inline
 GitHub Actions agent	Every pull request	Sticky PR comment + fails the check on critical findings
 CLI + dashboard	Local + CI	Batch audit + auto-remediation patches

The middle row is the **DORA Gatekeeper move** — non-compliant code stops merging.

Drop one YAML file into a repo → every PR is gated by a Bob-powered auditor

The ROI math

Status quo	With Sentinel as CI gate
\$50K × 2/yr in external audit fees	\$0
4 engineer-months/yr on audit follow-up	< 1 engineer-day/yr
Mean time to discover a HIPAA violation: months	Before the PR merges
Mean post-shipping fix cost: \$10K–\$50K	0 — never shipped
Per-PR Sentinel cost:	\$0.03 of API spend

Net structural cost-out: **\$100K+/year per repo.**

Setup time: **10 minutes** — install one workflow + commit
one YAML file.

Built with Bob IDE — receipts

Bob IDE task	Output	Cost
Audit run via <code>hipaa-auditor</code> mode	JSON findings + auditor notes	\$0.10
Add §164.310 control end-to-end	4 files changed, demo violation seeded	\$1.49
Generate test suite	679 LOC, 30 tests, 30 passing	\$0.39
Refactor dirty-tree no-op	Structured status across CLI + dashboard	\$1.09
Code-review catalog	False-positive / false-negative analysis	\$0.07
Generate per-control docs	26 markdown pages in <code>docs/controls/</code>	\$2.92
	Total: \$6.06 / 40 Bobcoins	

Why this matters to IBM

Compliance is the killer enterprise use case Bob IDE was built for.

Healthcare, fintech, gov: IBM's existing customer base. They can't ship without HIPAA, PCI, FedRAMP.

Sentinel makes Bob IDE the answer to a \$50B/year enterprise spend.

Drop `.bob/custom_modes.yaml` into any project → every developer becomes a compliance-aware coder. No external auditors. No six-month cycles. No spreadsheets.

Thank you.

github.com/vaatus/sentinel

Built with IBM Bob IDE · May 2026

Try it: `git clone ... && npm install && npm run demo`